

Utiliser Les Proxies Web

CatRégorie : ⚔ Offensif
Durée Estimée : 8 heures
Difficulté : Easy, Box II

Introduction aux Proxies Web :

Le proxy fonctionne en interceptant les requetes entre le client (navigateur ou application mobile) et le serveur back-end. Le test de ces requetes constitue l'essentielle du test d'intrusion d'applications web. Le proxy web permet donc d'intercepter, inspecter modifier et rejouer ce trafic. Nous utiliserons ici deux des proxy web les plus courants : BurpSuite avec une version gratuite et une version pro payante et OWASP ZAP entièrement gratuite et open-source

Configuration du Proxy:

Il faut apprendre à manier la fonctionnalité la plus utilisé le proxy web, en configurant (le proxy de) notre navigateur il envoi les trafic en local sur le port 8080 (dipend des configurations) L'outil proxy l'y recupère c'est là qu'on peu l'analyser et le modifier avant qu'il reparte sur internet ou vers notre navigateur
Les deux outils BurpSuite et Zap possèdent un navigateur préconfiguré... Mais il est plus facile de configurer un proxy manuellement dans notre bon vieux Firefox.
On peux configurer le proxy manuellement dans Firefox...
Note : Si on veux servir le proxy web sur un port different du 8080 par defaut on peux le faire dans Burp sous (Proxy => Parametre du Proxy => Ecouteurs du proxy) ou dans ZAP sous (Outils => Options => Reseau => Serveurs / Proxys Locaux). Dans les deux cas nous devons nous assurer que le proxy configuré dans Firefox utilise le même port. Afin de changer manuellement on peux utiliser l'extension de navigateur Foxy Proxy

Une autre étape est l'installation des certificats d'autorité du proxy web sans ça on devrai cliquer sur continuer a chaque site web ou on serait juste bloqué par l'HSTS.
Pour obtenir les certificats d'authorité de burp il suffit d'aller sur http://burp et pour OWASP ZAP on va sur (Outils => Options => Réseau => Certificats du serveur) puis on clique sur Save.
Une fois que nous avons ces certificats on peux les installer dans Firefox en naviguant sur about:preferences#privacy en suite clique sur l'onglet Authorities puis Importer et on selectionne le certificat téléchargé en lui donnant les privileges requis

L'interception des requetes Web :

Pour Burp on peux naviguer vers l'onglet Proxy on peux activer et desactiver l'interception des requetes avec le 'Intercept ON/OFF tout le trafic est comme enregistrer si l'interception est désactivé il est juste "copier à la volée" Quand la requete est interceptée on à bien sûr le bouton forward pour la "laisser reporter"

Pour ZAP je trouve le procesus un peu plus complexe L'interception est désactivé par defaut elle s'active en appuyant sur le petit bouton vert qui passera rouge ou avec le raccourci clavier Ctrl b Ensuite on peu choisir sur la petite icone le navigateurs préconfiguré à lancer. ZAP dispose également d'une fonctionnalité puissante appellée HUD